



— CONFIDENCIAL —

AUDITORÍAS Y CONFORMIDAD

Informe de Auditoría Interna

Sistema de Gestión de Ciberseguridad (SGCIB) — Versión Expandida

VERSIÓN EXPANDIDA · V2.0

ORGANIZACIÓN	Laboratorio Clínico ACLIN Ltda.
NORMATIVA APLICABLE	Ley Marco de Ciberseguridad N°21.663
NORMAS DE REFERENCIA	Ley 21.663 · ISO/IEC 27001:2022 · ISO 19011
PERÍODO EVALUADO	Octubre 2025 — Abril 2026
FECHA DE EMISIÓN	15 de Abril de 2026
AUDITOR RESPONSABLE	Jaime Gómez Ayala
CISO / ENCARGADO	Paulina Tapia Hernández
VERSIÓN	2.0 — Expandida
NIVEL DE CUMPLIMIENTO	87% — Cumplimiento Parcial
CLASIFICACIÓN	Confidencial — Uso Interno

TABLA DE CONTENIDOS

• 1. Objetivo de la Auditoría	2
• 2. Alcance de la Auditoría	2
• 3. Metodología	3
• 4. Marco Regulatorio	3
• 5. Hallazgos Detallados	4
• 6. Matriz de Conformidad con Ley 21663	10
• 7. Plan de Mejora	11
• 8. Conclusiones	13
• 9. Recomendaciones	15
• 10. Firmas y Autorizaciones	16

1. OBJETIVO DE LA AUDITORÍA

Evaluar el cumplimiento del Laboratorio Clínico ACLIN Ltda. con los requisitos establecidos en la Ley Marco de Ciberseguridad N°21.663, verificar la implementación efectiva del Sistema de Gestión de Ciberseguridad (SGCIB), identificar vulnerabilidades y brechas de cumplimiento, y proporcionar recomendaciones para la mejora continua del posicionamiento de seguridad de la organización.

Nota: Al cierre del presente informe, dos controles se mantienen en estado pendiente por parte de ACLIN: la implementación de autenticación multifactor (MFA) y la entrega de contratos formalizados con terceros y proveedores tecnológicos.

2. ALCANCE DE LA AUDITORÍA

Áreas Evaluadas:

- Gobierno de Ciberseguridad (Comité, CISO, estructura)
- Políticas y Procedimientos de Seguridad
- Control de Accesos e Identidades
- Gestión de Riesgos y Activos Críticos
- Gestión de Incidentes y Respuesta a Crisis
- Continuidad Operacional y Recuperación ante Desastres
- Encriptación y Protección de Datos
- Monitoreo y Detección de Amenazas
- Capacitación y Conciencia en Ciberseguridad
- Auditoría y Cumplimiento Normativo

Período Evaluado:

Octubre 2025 – Abril 2026 (7 meses de operación)

No Incluye:

- Auditoría de cumplimiento con normas específicas de la industria médica (más allá del requisito de Ley 21663), evaluación de infraestructura física (acceso a instalaciones), análisis forense de incidentes.

3. METODOLOGÍA

La auditoría se realizó conforme a los lineamientos de ISO/IEC 19011, utilizando un enfoque combinado de:

- **Revisión Documental:** Análisis de políticas, procedimientos, planes y registros
- **Entrevistas:** Conversaciones con responsables de procesos clave
- **Verificación de Evidencia:** Validación de implementación de controles
- **Análisis de Registros:** Revisión de logs, reportes y documentación de incidentes
- **Evaluación de Riesgos:** Metodología ISO 27005 para análisis de brecha

4. MARCO REGULATORIO

4.1 Ley Marco de Ciberseguridad N°21.663

Artículo	Requisito
Art. 6	Sistema de Gestión de Ciberseguridad (SGCIB) obligatorio
Art. 8	Comité de Ciberseguridad (mín. 5 miembros) — Reuniones trimestrales
Art. 10	Plan de Continuidad (BCP) y Recuperación (DRP) obligatorios
Art. 12	Control de Accesos con MFA para sistemas críticos
Art. 13	Encriptación de datos en tránsito (TLS 1.2+) y reposo (AES 256+)
Art. 14	Capacitación obligatoria (anual, 100% personal)
Art. 16	Auditoría interna anual con cobertura total
Art. 17	Monitoreo continuo (logs mín. 90 días)

Art. 24

Reporte de incidentes: CRÍTICO 24h, ALTO 48h, MEDIO 72h

4.2 Normas de Referencia

- ISO/IEC 27001:2022 — Requisitos para Sistemas de Gestión de Seguridad de la Información
- ISO/IEC 27002:2022 — Código de práctica para controles de seguridad
- ISO/IEC 27005 — Gestión del riesgo de la seguridad de la información
- ISO 19011 — Directrices para la auditoría de sistemas de gestión

5. HALLAZGOS DETALLADOS

Total de hallazgos identificados: 22 (3 CRÍTICOS · 7 ALTOS · 8 MEDIOS · 4 BAJOS) + 5 hallazgos Ethical Hacking + 1 hallazgo forense

Hallazgos con estado PENDIENTE por parte de ACLIN: H-004 (MFA) y contratos con terceros.

H-001: Plan de Continuidad Operacional

Clasificación	CRÍTICO
Descripción	El Plan de Continuidad de Negocios (BCP) y Plan de Recuperación ante Desastres (DRP) estaban documentados pero no completamente probados. Art. 10 Ley 21663 requiere pruebas funcionales mínimo anual.
Evidencia / Estado	<i>Registros de pruebas incompletos en el momento de la auditoría (1 de 4 simulacros planeados). Estado actual: Remediado.</i>
Impacto	Riesgo de incapacidad de recuperación ante incidente crítico
Plazo / Resultado	Remediado — 15 días

H-002: Encriptación de Datos en Reposo

Clasificación	CRÍTICO
----------------------	----------------

Descripción	Art. 13 requiere encriptación AES 256+ para datos sensibles. Las bases de datos críticas no habían sido auditadas para validar el estándar mínimo.
Evidencia / Estado	<i>Falta evidencia técnica de configuración al momento de la auditoría. Estado actual: Validado y conforme.</i>
Impacto	Exposición potencial de información de salud (PII)
Plazo / Resultado	Remediado — 15 días

H-003: Monitoreo de Accesos Privilegiados

Clasificación	CRÍTICO
Descripción	No se evidenciaba monitoreo continuo de cuentas privilegiadas (admin, root). Art. 17 requiere logging continuo con retención mín. 90 días.
Evidencia / Estado	<i>Ausencia de logs de auditoría para accesos administrativos al inicio del período. Estado actual: Implementado y operativo.</i>
Impacto	Incapacidad de detectar accesos no autorizados
Plazo / Resultado	Remediado — 15 días

H-004: MFA en Sistemas Críticos

Clasificación	ALTO
Descripción	Art. 12 obliga MFA para sistemas con información crítica. Sistemas de gestión de laboratorio e historiales de pacientes accesibles con solo usuario/contraseña.
Evidencia / Estado	<i>Estado actual: MFA NO IMPLEMENTADO — Pendiente de implementación por parte de ACLIN. Control técnico requerido por Ley 21.663 Art. 12.</i>
Impacto	Riesgo de compromiso de cuentas de usuario — Artículo 12 Ley 21.663 incumplido

Plazo / Resultado	PENDIENTE — Responsabilidad de ACLIN
--------------------------	--------------------------------------

H-005: Revisión Trimestral de Accesos

Clasificación	ALTO
Descripción	Art. 12 requiere revisión mínimo trimestral de permisos. La revisión se realizaba pero no estaba documentada en actas formales.
Evidencia / Estado	<i>Falta documentación de revisiones Q1 y Q2. Estado actual: Proceso formalizado con actas firmadas.</i>
Impacto	Acumulación de accesos innecesarios (privilege creep)
Plazo / Resultado	Remediado — 30 días

H-006: Evaluación de Riesgos

Clasificación	ALTO
Descripción	La evaluación de riesgos basada en ISO 27005 debe ser cuantitativa o cualitativa. La versión inicial era simplificada sin criterios claros de probabilidad/impacto.
Evidencia / Estado	<i>Matriz de riesgos sin escala numérica ni metodología documentada. Estado actual: Matriz ISO 27005 completa implementada.</i>
Impacto	Imposibilidad de priorizar remediación de controles
Plazo / Resultado	Remediado — 30 días

H-007: Procedimiento de Respuesta a Incidentes

Clasificación	ALTO
Descripción	El procedimiento existía pero no incluía escalación clara a ANCI según plazos del Art. 24 (24h crítico, 48h alto, 72h medio).

Evidencia / Estado	<i>Sin definición de criterios de clasificación ni plantillas de notificación. Estado actual: Procedimiento actualizado con escalación ANCI.</i>
Impacto	Retraso en notificación a autoridades regulatorias
Plazo / Resultado	Remediado — 30 días

H-008: Registro de Capacitación

Clasificación	ALTO
Descripción	Art. 14 requiere capacitación anual al 100% del personal. El turno noche del laboratorio no tenía evidencia de capacitación registrada.
Evidencia / Estado	<i>8 de 45 empleados sin constancia de capacitación al momento de la auditoría. Estado actual: 100% del personal capacitado y certificado.</i>
Impacto	Brecha de cumplimiento regulatorio
Plazo / Resultado	Remediado — 30 días

H-009: Documentación del Comité

Clasificación	MEDIO
Descripción	El Comité debe reunirse trimestralmente según Art. 8. Las actas de Q1 (enero) no tenían registro de decisiones sobre ciberseguridad.
Evidencia / Estado	<i>Acta de enero sin punto de orden sobre seguridad o incidentes. Estado actual: Actas formalizadas con registro completo.</i>
Impacto	Falta evidencia de governance según ley
Plazo / Resultado	Remediado — 60 días

H-010: Inventario de Activos Críticos

Clasificación	MEDIO
----------------------	--------------

Descripción	No existía documento formalizado con lista de activos críticos, necesario para la evaluación de riesgos.
Evidencia / Estado	<i>Ausencia de inventario de activos críticos al inicio del período. Estado actual: Inventario formalizado y vigente.</i>
Impacto	Dificulta priorización de controles de seguridad
Plazo / Resultado	Remediado — 60 días

(Hallazgos H-011 a H-022 incluidos en anexo — 12 hallazgos adicionales MEDIO y BAJO, todos remediados)

Hallazgo adicional — Contratos con Terceros y Proveedores

H-023: Contratos con Terceros no Entregados

Clasificación	ALTO
Descripción	Los contratos formalizados con terceros y proveedores tecnológicos que acceden a sistemas de información de ACLIN no han sido entregados al auditor externo. La Ley 21.663 y la norma ISO 27001:2022 exigen cláusulas de seguridad y confidencialidad con terceros.
Evidencia / Estado	<i>Estado actual: PENDIENTE DE ENTREGA por parte de ACLIN. Documentación no proporcionada durante el período de auditoría.</i>
Impacto	Ausencia de obligaciones contractuales de seguridad con terceros — riesgo de exposición de datos sensibles
Plazo / Resultado	PENDIENTE — Responsabilidad de ACLIN

Hallazgos de Ethical Hacking — Todos Remediados

FC-001: Vulnerabilidad IDOR — Portal Pacientes (NIVEL4, Oct 2025)

Clasificación	CRÍTICO
Descripción	Vulnerabilidad IDOR identificada y explotada en el portal pacientes.aclin.cl durante el período de evaluación. Extracción no autorizada de ~21.000 registros de exámenes. INC-2025-003. Corrección aplicada, validada por equipo forense NIVEL4.
Evidencia / Estado	<i>Informe Forense NIVEL4 v1.0 — 17/10/2025. Ley 21.663 Art. 9.</i>
Impacto	Exposición masiva de datos sensibles de pacientes
Plazo / Resultado	Resuelto. Notificación CSIRT completada. Control preventivo implementado.

EH-001: MSSQL Expuesto a Internet — Puerto 1122

Clasificación	CRÍTICO
Descripción	Microsoft SQL Server 2019 accesible desde Internet en puerto 1122/TCP. Identificado durante el ejercicio de Ethical Hacking perimetral realizado por Kimsa.
Evidencia / Estado	<i>Informe EH Perimetral Kimsa — Jaime Gómez Ayala. OWASP Top 10. Ley 21.663 Art. 8.</i>
Impacto	Acceso directo a base de datos clínica desde Internet
Plazo / Resultado	Resuelto. Puerto cerrado, acceso restringido a red interna segmentada.

EH-002: Comunicación HTTP Sin Cifrar — Portal Pacientes

Clasificación	CRÍTICO
Descripción	Portal pacientes.aclin.cl operaba sobre HTTP sin cifrar, exponiendo credenciales y resultados clínicos en tránsito. CWE-319.
Evidencia / Estado	<i>Informe EH Perimetral Kimsa. Ley 21.663 Art. 13.</i>

Impacto	Credenciales y datos clínicos en texto plano
Plazo / Resultado	Resuelto. Migración completa a HTTPS con certificado TLS 1.3 activo.

EH-003: Fingerprinting de Software

Clasificación	ALTO
Descripción	El servidor revelaba versión completa de plataforma: IIS 10.0 y SQL Server 2019. Facilita ataques dirigidos a versiones específicas.
Evidencia / Estado	<i>OWASP Testing Guide 4.01. Kimsa EH Report.</i>
Impacto	Facilita ataques dirigidos
Plazo / Resultado	Resuelto. Cabeceras de versión suprimidas en configuración IIS.

EH-004: Encabezados HTTP de Seguridad Faltantes

Clasificación	MEDIO
Descripción	Ausencia de Referrer-Policy, X-Content-Type-Options, X-Frame-Options, CSP y X-XSS-Protection en el portal de pacientes.
Evidencia / Estado	<i>Kimsa EH Report.</i>
Impacto	Múltiples vectores de ataque web
Plazo / Resultado	Resuelto. Todos los encabezados configurados en web.config de IIS.

EH-005: Ausencia de Archivo security.txt

Clasificación	BAJO
Descripción	No existía /.well-known/security.txt en el portal, limitando el canal formal para reporte de vulnerabilidades.

Evidencia / Estado	RFC 9116.
Impacto	Canal de reporte de vulnerabilidades no disponible
Plazo / Resultado	Resuelto. Archivo security.txt publicado con canales de reporte definidos.

6. MATRIZ DE CONFORMIDAD CON LEY 21663

Artículo	Requisito	Estado	Evidencia
6	Sistema de Gestión SGCIB	Conforme	Políticas y procedimientos documentados e implementados
8	Comité de Ciberseguridad (5+)	Conforme	Comité constituido con actas formalizadas
10	BCP/DRP y Pruebas	Conforme	Documentos validados y simulacros completados
12	Control de Accesos + MFA	Pendiente	MFA NO implementado por ACLIN — Control técnico pendiente
13	Encriptación de datos	Conforme	TLS 1.2+ en tránsito, AES 256+ en reposo validado
14	Capacitación 100% anual	Conforme	100% del personal capacitado y certificado
16	Auditoría anual interna	Conforme	Auditoría realizada — presente informe
17	Monitoreo continuo 90 días	Conforme	Logging privilegiado implementado, retención 90+ días

24	Reporte incidentes 24–72h	Conforme	Procedimiento de escalación ANCI formalizado
Gral.	Contratos con Terceros	Pendiente	Contratos no entregados por ACLIN — Pendiente de regularización
Gral.	NIVEL DE CUMPLIMIENTO TOTAL	87%	28 de 30 requisitos conformes — 2 pendientes por ACLIN

7. PLAN DE MEJORA

La mayoría de las acciones correctivas han sido ejecutadas y verificadas. Los siguientes hallazgos permanecen PENDIENTES de acción por parte de ACLIN:

Hallazgo	Acción Correctiva	Responsable	Plazo	Resultado
H-001	Pruebas BCP/DRP ejecutadas	Paulina Tapia H.	15 d	✓ 3 simulacros completados
H-002	Encriptación auditada y validada	Paulina Tapia H.	15 d	✓ 100% en reposo AES 256+
H-003	Logging privilegiado implementado	Paulina Tapia H.	15 d	✓ Logs 90+ días activos
H-004	MFA activación en sistemas críticos	ACLIN — Pendiente	30 d	NO IMPLEMENTADO — Pendiente por ACLIN
H-005	Revisiones trimestrales formalizadas	Paulina Tapia H.	30 d	✓ Actas Q1 y Q2 firmadas
H-006	Evaluación riesgos ISO 27005 completa	Paulina Tapia H.	30 d	✓ Matriz cuantitativa vigente

H-007	Procedimiento respuesta actualizado	Paulina Tapia H.	30 d	✓ Escalación ANCI documentada
H-008	Personal capacitado al 100%	Paulina Tapia H.	30 d	✓ 45 de 45 empleados certificados
H-009	Actas del Comité formalizadas	M. Ignacia Tapia B.	60 d	✓ Actas con decisiones registradas
H-010	Inventario de activos creado	Paulina Tapia H.	60 d	✓ Inventario vigente y formalizado
H-011	Políticas clasificación actualizadas	Paulina Tapia H.	60 d	✓ Política revisada y aprobada
H-012	SIEM y alertas implementadas	Paulina Tapia H.	90 d	✓ Monitoreo centralizado activo
H-023	Entrega de contratos con terceros	ACLIN — Pendiente	30 d	NO ENTREGADOS — Pendiente por ACLIN

8. CONCLUSIONES

Nivel de Cumplimiento:

87% — CUMPLIMIENTO PARCIAL — 2 controles PENDIENTES por acción de ACLIN

Interpretación:

El Laboratorio Clínico ACLIN Ltda. ha implementado y formalizado la gran mayoría de los controles de ciberseguridad exigidos por la Ley Marco N°21.663. Los hallazgos identificados durante el período de evaluación fueron en su mayoría remediados dentro de los plazos establecidos. Sin embargo, al cierre de este informe, dos controles permanecen pendientes de acción por parte de ACLIN:

- H-004: Autenticación Multifactor (MFA) — no implementada en sistemas críticos (Art. 12 Ley 21.663). Pendiente de implementación técnica por parte de ACLIN.
- H-023: Contratos con terceros y proveedores — no entregados al auditor externo. Pendiente de regularización por parte de ACLIN.

La conformidad normativa integral no puede declararse hasta que ACLIN complete ambas acciones pendientes.

Fortalezas Consolidadas:

- Governance sólido: Comité de Ciberseguridad constituido con roles y responsabilidades definidas
- Marco documental completo: políticas y procedimientos alineados con Ley 21663 e ISO 27001
- Capacitación integral: 100% del personal capacitado y certificado en ciberseguridad
- Continuidad operacional validada: BCP/DRP con simulacros completados y documentados
- Control técnico parcial: encriptación AES 256+, logging privilegiado y SIEM activos — MFA PENDIENTE
- Respuesta a incidentes estructurada: procedimiento con escalación ANCI según Art. 24

Hallazgos de Ethical Hacking e Informe Forense — Todos Remediados

FC-001: Vulnerabilidad IDOR — Portal Pacientes (NIVEL4, Oct 2025)

Clasificación	CRÍTICO
Descripción	Vulnerabilidad IDOR identificada y explotada en el portal pacientes.aclin.cl. Extracción no autorizada de ~21.000 registros. INC-2025-003.
Evidencia / Estado	Informe Forense NIVEL4 v1.0 — 17/10/2025. Ley 21.663 Art. 9.
Impacto	Exposición masiva de datos de pacientes

Plazo / Resultado

Resuelto. Notificación CSIRT completada. Control preventivo implementado.

9. RECOMENDACIONES

Acciones Inmediatas — Pendientes de ACLIN

1. Implementar MFA en todos los sistemas críticos (Art. 12 Ley 21.663) a la brevedad posible. Prioridad máxima.
2. Entregar los contratos formalizados con terceros y proveedores tecnológicos al auditor externo para su revisión y archivo.

Mantenimiento Continuo

3. Mantener el programa de auditoría interna trimestral conforme a ISO 19011
4. Ejecutar simulacros BCP/DRP anuales y documentar resultados con evidencia
5. Actualizar la matriz de riesgos ISO 27005 ante cambios en infraestructura

Evolución del Sistema

6. Evaluar la certificación ISO 27001:2022 para posicionamiento regulatorio avanzado
7. Revisar y actualizar políticas de clasificación de datos ante cambios tecnológicos
8. Ampliar el alcance del SIEM incorporando alertas de comportamiento anómalo (UEBA)

Governance y Cultura

9. Mantener el ciclo de capacitación anual con evaluación de conocimientos
10. Extender el programa de concientización a proveedores críticos de tecnología
11. Establecer KPIs de ciberseguridad en el reporte ejecutivo trimestral al directorio

10. FIRMAS Y AUTORIZACIONES

Este informe es confidencial y de uso interno exclusivo del Laboratorio Clínico ACLIN Ltda. y su Comité de Ciberseguridad.

Nombre y Cargo	Fecha	Firma
Jaime Gómez Ayala Auditor Externo	____ / ____ / 2026	_____ _____
M. Ignacia Tapia Baldassare Presidente Comité de Ciberseguridad	____ / ____ / 2026	_____ _____
Paulina Tapia Hernández CISO / Representante Área TI	____ / ____ / 2026	_____ _____
Marcelo Tapia Carrere Presidente / CEO de ACLIN	____ / ____ / 2026	_____ _____